



ZAP by
Checkmarx

ZAP by Checkmarx Scanning Report

Site: <https://www.ali-tech.com>

Generated on Sun, 12 Jul 2026 08:55:23

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	2
Low	3
Informational	5

Alerts

Name	Risk Level	Number of Instances
Content Security Policy (CSP) Header Not Set	Medium	Systemic
Cross-Domain Misconfiguration	Medium	Systemic
Big Redirect Detected (Potential Sensitive Information Leak)	Low	2
Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)	Low	Systemic
X-Content-Type-Options Header Missing	Low	1
Information Disclosure - Sensitive Information in URL	Informational	3
Modern Web Application	Informational	2
Re-examine Cache-control Directives	Informational	Systemic
Retrieved from Cache	Informational	Systemic
User Controllable HTML Element Attribute (Potential XSS)	Informational	6

Alert Detail

Medium	Content Security Policy (CSP) Header Not Set
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page

	— covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	https://www.alii-tech.com/
Node Name	https://www.alii-tech.com/
Method	GET
Attack	
Evidence	
Other Info	
URL	https://www.alii-tech.com/about
Node Name	https://www.alii-tech.com/about
Method	GET
Attack	
Evidence	
Other Info	
URL	https://www.alii-tech.com/blog
Node Name	https://www.alii-tech.com/blog
Method	GET
Attack	
Evidence	
Other Info	
URL	https://www.alii-tech.com/summer-tech-ai
Node Name	https://www.alii-tech.com/summer-tech-ai
Method	GET
Attack	
Evidence	
Other Info	
URL	https://www.alii-tech.com/why-ai
Node Name	https://www.alii-tech.com/why-ai
Method	GET
Attack	
Evidence	
Other Info	
Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP

Reference	https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Medium	Cross-Domain Misconfiguration
Description	Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server.
URL	https://www.ali-tech.com/
Node Name	https://www.ali-tech.com/
Method	GET
Attack	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	https://www.ali-tech.com/about
Node Name	https://www.ali-tech.com/about
Method	GET
Attack	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	https://www.ali-tech.com/robots.txt
Node Name	https://www.ali-tech.com/robots.txt
Method	GET
Attack	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	https://www.ali-tech.com/sitemap.xml
Node	

Name	https://www.ali-tech.com/sitemap.xml
Method	GET
Attack	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	https://www.ali-tech.com/summer-tech-ai
Node Name	https://www.ali-tech.com/summer-tech-ai
Method	GET
Attack	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
Instances	Systemic
Solution	Ensure that sensitive data is not available in an unauthenticated manner (using IP address white-listing, for instance). Configure the "Access-Control-Allow-Origin" HTTP header to a more restrictive set of domains, or remove all CORS headers entirely, to allow the web browser to enforce the Same Origin Policy (SOP) in a more restrictive manner.
Reference	https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy
CWE Id	264
WASC Id	14
Plugin Id	10098

Low	Big Redirect Detected (Potential Sensitive Information Leak)
Description	The server has responded with a redirect that seems to provide a large response. This may indicate that although the server sent a redirect it also responded with body content (which may include sensitive details, PII, etc.).
URL	https://www.ali-tech.com/admin
Node Name	https://www.ali-tech.com/admin
Method	GET
Attack	
Evidence	
Other Info	Location header URI length: 12 [/admin/login]. Predicted response size: 312. Response Body Length: 17,274.
URL	https://www.ali-tech.com/dashboard
Node	

Name	https://www.ali-tech.com/dashboard
Method	GET
Attack	
Evidence	
Other Info	Location header URI length: 16 [/dashboard/login]. Predicted response size: 316. Response Body Length: 15,878.
Instances	2
Solution	Ensure that no sensitive information is leaked via redirect responses. Redirect responses should have almost no content.
Reference	
CWE Id	201
WASC Id	13
Plugin Id	10044

Low	Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)
Description	The web/application server is leaking information via one or more "X-Powered-By" HTTP response headers. Access to such information may facilitate attackers identifying other frameworks /components your web application is reliant upon and the vulnerabilities such components may subject to.
URL	https://www.ali-tech.com/admin
Node Name	https://www.ali-tech.com/admin
Method	GET
Attack	
Evidence	X-Powered-By: Next.js
Other Info	
URL	https://www.ali-tech.com/admin/login
Node Name	https://www.ali-tech.com/admin/login
Method	GET
Attack	
Evidence	X-Powered-By: Next.js
Other Info	
URL	https://www.ali-tech.com/dashboard
Node Name	https://www.ali-tech.com/dashboard
Method	GET
Attack	
Evidence	X-Powered-By: Next.js
Other Info	
URL	https://www.ali-tech.com/enroll
Node	

Name	https://www.alii-tech.com/enroll
Method	GET
Attack	
Evidence	X-Powered-By: Next.js
Other Info	
URL	https://www.alii-tech.com/enroll?age=5&city=East+Romaineburgh&country=ZAP&courseSlug=a-school-work&email=zaproxy%40example.com&fullName=ZAP&howHeard=Social+media&parentName=ZAP&phone=9999999999&school=
Node Name	https://www.alii-tech.com/enroll (age,city,country,courseSlug,email,fullName,howHeard,parentName,phone,school)
Method	GET
Attack	
Evidence	X-Powered-By: Next.js
Other Info	
Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to suppress "X-Powered-By" headers.
Reference	https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework https://www.troyhunt.com/shhh-dont-let-your-response-headers/
CWE Id	497
WASC Id	13
Plugin Id	10037

Low	X-Content-Type-Options Header Missing
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	https://www.alii-tech.com/_next/image?q=75&url=https%3A%2F%2Fi.yimg.com%2Fvi%2F44Dhxval8OY%2Fmaxresdefault.jpg&w=1920
Node Name	https://www.alii-tech.com/_next/image (q,url,w)
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Instances	1
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application /web server to not perform MIME-sniffing.

Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security_Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informational	Information Disclosure - Sensitive Information in URL
Description	The request appeared to contain sensitive information leaked in the URL. This can violate PCI and most organizational compliance policies. You can configure the list of strings for this check to add or remove values specific to your environment.
URL	https://www.alii-tech.com/contact?email=zaproxy%40example.com&message=Zaproxy+alias+impedit+expedita+quisquam+pariatur+exercitationem.+Nemo+rerum+eveniet+dolores+rem+quia+dignissimos.&name=ZAP&subject=Zaproxy+dolore+alias+impedit+expedita+quisquam.
Node Name	https://www.alii-tech.com/contact (email,message,name,subject)
Method	GET
Attack	
Evidence	zaproxy@example.com
Other Info	The URL contains email address(es).
URL	https://www.alii-tech.com/enroll?age=5&city=East+Romaineburgh&country=ZAP&course=prom engineering&courseSlug=ai-for-school-work&email=zaproxy%40example.com&fullName=ZAP&howHeard=Social+media&parentName=ZAP&phone=9999999999&school
Node Name	https://www.alii-tech.com/enroll (age,city,country,course,courseSlug,email,fullName,howHeard,parentName,phone,school)
Method	GET
Attack	
Evidence	zaproxy@example.com
Other Info	The URL contains email address(es).
URL	https://www.alii-tech.com/enroll?age=5&city=East+Romaineburgh&country=ZAP&courseSlug=ai-for-school-work&email=zaproxy%40example.com&fullName=ZAP&howHeard=Social+media&parentName=ZAP&phone=9999999999&school
Node Name	https://www.alii-tech.com/enroll (age,city,country,courseSlug,email,fullName,howHeard,parentName,phone,school)
Method	GET
Attack	
Evidence	zaproxy@example.com
Other Info	The URL contains email address(es).
Instances	3
Solution	Do not pass sensitive information in URIs.
Reference	
CWE Id	598
WASC Id	13
Plugin Id	10024

Informational	Modern Web Application
---------------	------------------------

Description	The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one.
URL	https://www.alii-tech.com/admin
Node Name	https://www.alii-tech.com/admin
Method	GET
Attack	
Evidence	<script src="/_next/static/chunks/27jktro2p5rq9.js" async=""></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	https://www.alii-tech.com/dashboard
Node Name	https://www.alii-tech.com/dashboard
Method	GET
Attack	
Evidence	<script src="/_next/static/chunks/27jktro2p5rq9.js" async=""></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
Instances	2
Solution	This is an informational alert and so no changes are required.
Reference	
CWE Id	
WASC Id	
Plugin Id	10109

Informational	Re-examine Cache-control Directives
Description	The cache-control header has not been set properly or is missing, allowing the browser and proxies to cache content. For static assets like css, js, or image files this might be intended, however, the resources should be reviewed to ensure that no sensitive content will be cached.
URL	https://www.alii-tech.com/
Node Name	https://www.alii-tech.com/
Method	GET
Attack	
Evidence	public, max-age=0, must-revalidate
Other Info	
URL	https://www.alii-tech.com/about
Node Name	https://www.alii-tech.com/about
Method	GET
Attack	
Evidence	public, max-age=0, must-revalidate
Other Info	
URL	https://www.alii-tech.com/robots.txt

Node Name	https://www.ali-tech.com/robots.txt
Method	GET
Attack	
Evidence	public, max-age=0, must-revalidate
Other Info	
URL	https://www.ali-tech.com/sitemap.xml
Node Name	https://www.ali-tech.com/sitemap.xml
Method	GET
Attack	
Evidence	public, max-age=0, must-revalidate
Other Info	
URL	https://www.ali-tech.com/summer-tech-ai
Node Name	https://www.ali-tech.com/summer-tech-ai
Method	GET
Attack	
Evidence	public, max-age=0, must-revalidate
Other Info	
Instances	Systemic
Solution	For secure content, ensure the cache-control HTTP header is set with "no-cache, no-store, must-revalidate". If an asset should be cached consider setting the directives "public, max-age, immutable".
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-content-caching https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cache-Control https://grayduck.mn/2021/09/13/cache-control-recommendations/
CWE Id	525
WASC Id	13
Plugin Id	10015

Informational	Retrieved from Cache
Description	The content was retrieved from a shared cache. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where caching servers such as "proxy" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.
URL	https://www.ali-tech.com/
Node Name	https://www.ali-tech.com/
Method	GET
Attack	
Evidence	Age: 83679

Other Info	The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
URL	https://www.ali-tech.com/
Node Name	https://www.ali-tech.com/
Method	GET
Attack	
Evidence	Age: 83680
Other Info	The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
URL	https://www.ali-tech.com/about
Node Name	https://www.ali-tech.com/about
Method	GET
Attack	
Evidence	Age: 83637
Other Info	The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
URL	https://www.ali-tech.com/robots.txt
Node Name	https://www.ali-tech.com/robots.txt
Method	GET
Attack	
Evidence	Age: 0
Other Info	The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
URL	https://www.ali-tech.com/sitemap.xml
Node Name	https://www.ali-tech.com/sitemap.xml
Method	GET
Attack	
Evidence	Age: 0
Other Info	The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
Instances	Systemic
Solution	Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user: Cache-Control: no-cache, no-store, must-revalidate, private Pragma: no-cache Expires: 0 This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.
Reference	https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231

	https://www.rfc-editor.org/rfc/rfc9110.html
CWE Id	525
WASC Id	
Plugin Id	10050

Informational	User Controllable HTML Element Attribute (Potential XSS)
Description	This check looks at user-supplied input in query string parameters and POST data to identify whether certain HTML attribute values might be controlled. This provides hot-spot detection for XSS (cross-site scripting) that will require further review by a security analyst to determine exploitability.
URL	https://www.alii-tech.com/enroll?age=5&city=East+Romaineburgh&country=ZAP&course=prompt-engineering&courseSlug=ai-for-school-work&email=zaproxy%40example.com&fullName=ZAP&howHeard=Social+media&parentName=ZAP&phone=9999999999&school=ZAP
Node Name	https://www.alii-tech.com/enroll (age,city,country,course,courseSlug,email,fullName,howHeard,parentName,phone,school)
Method	GET
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL: https://www.alii-tech.com/enroll?age=5&city=East+Romaineburgh&country=ZAP&course=prompt-engineering&courseSlug=ai-for-school-work&email=zaproxy%40example.com&fullName=ZAP&howHeard=Social+media&parentName=ZAP&phone=9999999999&school=ZAP appears to include user input in: a(n) [option] tag [value] attribute The user input found was: course=prompt-engineering The user-controlled value was: prompt-engineering
URL	https://www.alii-tech.com/enroll?age=5&city=East+Romaineburgh&country=ZAP&course=prompt-engineering&courseSlug=ai-for-school-work&email=zaproxy%40example.com&fullName=ZAP&howHeard=Social+media&parentName=ZAP&phone=9999999999&school=ZAP
Node Name	https://www.alii-tech.com/enroll (age,city,country,course,courseSlug,email,fullName,howHeard,parentName,phone,school)
Method	GET
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL: https://www.alii-tech.com/enroll?age=5&city=East+Romaineburgh&country=ZAP&course=prompt-engineering&courseSlug=ai-for-school-work&email=zaproxy%40example.com&fullName=ZAP&howHeard=Social+media&parentName=ZAP&phone=9999999999&school=ZAP appears to include user input in: a(n) [option] tag [value] attribute The user input found was: courseSlug=ai-for-school-work

	The user-controlled value was: ai-for-school-work
URL	https://www.alii-tech.com/enroll?age=5&city=East+Romaineburgh&country=ZAP&course=promengineering&courseSlug=ai-for-school-work&email=zaproxy%40example.com&fullName=ZAP&howHeard=Social+media&parentName=ZAP&phone=9999999999&school=ai-for-school-work
Node Name	https://www.alii-tech.com/enroll (age,city,country,course,courseSlug,email,fullName,howHeard,parentName,phone,school)
Method	GET
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL: https://www.alii-tech.com/enroll?age=5&city=East+Romaineburgh&country=ZAP&course=promengineering&courseSlug=ai-for-school-work&email=zaproxy%40example.com&fullName=ZAP&howHeard=Social+media&parentName=ZAP&phone=9999999999&school=ai-for-school-work appears to include user input in: a(n) [option] tag [value] attribute The user input found was: howHeard=Social media The user-controlled value was: social media
URL	https://www.alii-tech.com/enroll?age=5&city=East+Romaineburgh&country=ZAP&courseSlug=ai-for-school-work&email=zaproxy%40example.com&fullName=ZAP&howHeard=Social+media&parentName=ZAP&phone=9999999999&school=ai-for-school-work
Node Name	https://www.alii-tech.com/enroll (age,city,country,courseSlug,email,fullName,howHeard,parentName,phone,school)
Method	GET
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL: https://www.alii-tech.com/enroll?age=5&city=East+Romaineburgh&country=ZAP&courseSlug=ai-for-school-work&email=zaproxy%40example.com&fullName=ZAP&howHeard=Social+media&parentName=ZAP&phone=9999999999&school=ai-for-school-work appears to include user input in: a(n) [option] tag [value] attribute The user input found was: courseSlug=ai-for-school-work The user-controlled value was: ai-for-school-work
URL	https://www.alii-tech.com/enroll?age=5&city=East+Romaineburgh&country=ZAP&courseSlug=ai-for-school-work&email=zaproxy%40example.com&fullName=ZAP&howHeard=Social+media&parentName=ZAP&phone=9999999999&school=ai-for-school-work
Node	https://www.alii-tech.com/enroll (age,city,country,courseSlug,email,fullName,howHeard,parentName,phone,school)

Name	phone,school)
Method	GET
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL: https://www.alii-tech.com/enroll?age=5&city=East+Romaineburgh&country=ZAP&courseSlug=ai-for-school-work&email=zaproxy%40example.com&fullName=ZAP&howHeard=Social+media&parentName=ZAP&phone=9999999999&school=ai-for-school-work appears to include user input in: a(n) [option] tag [value] attribute The user input found was: howHeard=Social media The user-controlled value was: social media
URL	https://www.alii-tech.com/enroll?course=ai-for-school-work
Node Name	https://www.alii-tech.com/enroll (course)
Method	GET
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL: https://www.alii-tech.com/enroll?course=ai-for-school-work appears to include user input in: a(n) [option] tag [value] attribute The user input found was: course=ai-for-school-work The user-controlled value was: ai-for-school-work
Instances	6
Solution	Validate all input and sanitize output it before writing to any HTML attributes.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html
CWE Id	20
WASC Id	20
Plugin Id	10031